

Comportement et analyse de Fail2ban :

Exemple : Journalisation observée (interprétation) du 31 07 25 à 09h44 local time
Zulu Time / UTC time + 02h00 .

Timestamp	Action	IP	Explication
07:44:09	Found	80.94.95.116	1 ^{re} tentative échouée détectée
07:44:11	Found	80.94.95.116	2 ^e tentative échouée
07:44:11	Ban	80.94.95.116	► IP bannie (seuil atteint)
07:54:11	Unban	80.94.95.116	► Fin de bannissement (600 sec)

Analyse discriminante : caractéristiques

Élément	Fonction discriminante
IP	L'identifiant analysé
Regex (filter)	Condition d'entrée
maxretry	Seuil de déclenchement
findtime (sec)	Fenêtre d'observation des échecs
bantime (sec)	Durée d'exclusion

Très bien mais un attaquant connaît très bien ces règles et peut tenter des attaques soit continue soit espacer ses attaques. Car au bout de 10 minutes 600 secondes le bannissement cesse.

- On soulève une **limite fondamentale du modèle Fail2Ban** : Le bannissement temporaire et non persistant, même pour des IP récidivistes.

Problèmes pointés.

Un attaquant intelligent peut :

- Attendre 10 minutes (bantime = 600) puis recommencer.
- Éviter le seuil maxretry en espaçant les tentatives.
- Changer d'IP (IP dynamique ou VPN).

Pourquoi Fail2Ban ne "blackliste" pas par défaut ?

Raison

Détail technique ou stratégique

Conception stateless

Fail2Ban réagit aux logs récents, sans mémoire historique propre au service.

Risque de faux positifs

Certaines IP (ex : collaborateurs) peuvent échouer 3 fois légitimement.

Pas de base persistante

Par défaut, pas de fichier blacklist.txt ou système de score IP cumulé.

Simplicité et performance

Conçu pour être léger et réactif, sans mécanisme de tracking longue durée.

Solutions possibles : renforcer Fail2Ban

Option	Description technique
Persistent List	Ban Script cron ou actionban personnalisé pour ajouter l'IP à un fichier ou iptables-save
Cumulative ban	Augmenter bantime de manière exponentielle avec chaque nouvelle détection (via recidive jail)
Jail [recidive]	Jail spécifique fournie par défaut dans /etc/fail2ban/jail.conf
CrowdSec (alternative)	IDS collaboratif moderne, avec scores, bloat management, durée dynamique et partage de réputation IP.

Exemple de jail [recidive] dans Fail2Ban

[recidive]

enabled = true

logpath = /var/log/fail2ban.log

banaction = iptables-multiport

bantime = 86400 # 24h

findtime = 86400 # 24h

maxretry = 5

⚙ Elle détecte les IP bannies plusieurs fois par d'autres jails sur une journée → et les bannit pour 24h.

🔧 Ce que tu peux faire maintenant

1. ☒ Activer la jail recidive
2. ☒ Ajouter un script make blacklist → gère un fichier `/etc/fail2ban/blacklist.txt` injecté dans iptables
3. ☒ Ou intégrer CrowdSec comme fail2ban++ avec scoring, durée adaptative, réputation IP globale

Souhaites-tu que je te prépare la jail recidive activable directement ou le script de gestion de blacklist persistante ?